

Information Security & Management

Digital Assignment 1

Name: Joshua Vivian Francis

Case Study

On Thursday morning, John, an XYZ University employee, noticed a warning message on his computer saying that the system had been attacked by a worm, Win32.VB. Even though antivirus software was present on the system, it failed to detect the new worm because it had not been updated to the latest version. When John tried to open his e-mail, he experienced a slow internet connection and noticed some unusual file names on the disk. John immediately informed his colleague Bob, who checked his own computer and found the same problem. John and Bob checked several computers in the laboratories and discovered that the Win32.VB worm had infected many other machines. They contacted the system administrator, who checked the computers, reported the incident to the incident response team, and checked other laboratories as well. As a result, activities in the XYZ University laboratory were suspended for a day, causing a great inconvenience.

This case was later escalated to an autonomous organization founded in July 1986 that designs, develops, implements, and maintains IT systems, products, and services for one of the major government institutions in India. Governed by a board, the organization has a Managing Director as its top authority. Operating with 800 employees, it provides IT solutions, manages overall information systems, and gives IT consulting services to its parent organization. Headquartered in New Delhi, it has regional offices in five other Indian cities.

Question 1: Brief your key observation on the above case study

Our story begins with John, a student working diligently in a university lab. Suddenly, he encounters unusual system behaviour: applications running sluggishly, error messages popping up unexpectedly, and internet browsing speed taking a nosedive. These signs prompt John to investigate further.

John shares his concerns with his colleague, Bob. Together, they discuss the issue and follow the process for reporting suspicious activity. Through further investigation, they discover the culprit: a malicious worm spreading rapidly across the lab's computers.

The worm's presence disrupts normal lab operations. Classes are potentially delayed, research projects face setbacks, and deadlines may be missed, highlighting the real-world consequences of cyberattacks that extend far beyond technical issues.

Several key observations paint a picture of XYZ University's security vulnerabilities:

- **Outdated Antivirus Software:** The primary security lapse appears to be the university's failure to maintain updated antivirus software on its systems. This outdated software was ineffective against the worm's attack.
- **Alert Employee:** John's attentiveness and prompt action in informing his colleague demonstrate the value of a vigilant workforce.

- **Widespread Infection:** The worm's rapid spread suggests a lack of network segmentation or proper security controls. Without segmentation, the worm could jump from one infected computer to another with ease.
- **Disrupted Operations:** The one-day suspension of lab activities underscores the disruption caused by the cyberattack.
- **External Assistance:** Escalating the incident to an external organization suggests XYZ University lacked the internal resources or expertise to handle large-scale attacks.

Question 2: What Information Security policy do you recommend

Patch Management and Updates

- Implement a system for frequent updates of antivirus software, the operating system, and all applications.
- Automate patching processes for efficiency.
- Conduct vulnerability scanning to identify and prioritize patching of critical vulnerabilities based on exploit potential and severity.

Employee Awareness and Training

- Develop and deliver regular cybersecurity awareness training programs for all employees.
- Educate employees on common cyber threats, phishing scams, social engineering tactics, and best practices for secure computer usage.
- Train employees to identify suspicious activity and report security incidents promptly and effectively.

Incident Response Plan

- Establish a documented incident response plan outlining procedures for detection, reporting, containment, eradication, and recovery from security incidents.
- Define clear roles and responsibilities for the various stakeholders involved in incident response.
- Conduct regular tabletop exercises to test the incident response plan and identify areas for improvement.

Network Segmentation and Access Control

- Segment the university network to limit the lateral movement of attackers in case of a breach.
- Implement role-based access control to ensure users only access the data and systems they require for their job function.
- Enforce the principle of least privilege, granting users the minimum level of access necessary.

Data Security

- Implement data encryption for sensitive data at rest and in transit. This protects data even if intercepted.
- Utilize a Data Loss Prevention (DLP) solution to monitor and control the movement of sensitive data, preventing unauthorized exfiltration.

Vulnerability Management

- Conduct regular vulnerability assessments and penetration testing to identify and address security weaknesses before they can be exploited by attackers.

Third-Party Risk Management

- Develop a framework to assess the security posture of third-party vendors and service providers.
- Require vendors to adhere to the university's information security policy and undergo the required security assessments.

By implementing these recommendations, XYZ University can significantly improve its information security posture and be better prepared to prevent or mitigate future cyberattacks. This is just a starting point; as new threats evolve and new technologies emerge, XYZ University should continuously re-evaluate its security practices and adapt its strategies accordingly.

Question 3: List out the process and learning from the above situation

1. Detection: John's observation of unusual system behaviour and his prompt action in informing his colleague initiated the detection process.
2. Reporting: John and Bob likely followed established protocols to report the incident to the university IT department or a designated security contact.
3. Investigation: This involved utilizing system logs to identify infected machines, isolating infected machines to prevent further spread, and running antivirus scans to identify the specific worm variant.
4. Containment: The system administrator would likely isolate infected machines to prevent further lateral movement within the network. Steps might also be taken to determine the extent of the infection and identify any compromised data.
5. Eradication: Depending on the severity of the infection, the IT department might reboot infected machines in safe mode and run antivirus scans to remove the worm, reinstall operating systems if the worm is deeply embedded, and apply security updates and patches to all university systems to prevent similar attacks in the future.
6. Recovery: Affected labs would likely be shut down for a period to allow for restoration of data from backups (if available), verification of system functionality and data integrity, and re-deployment of applications and software.
7. Post-incident investigation: A post-incident investigation should be conducted to identify the root cause of the attack (which could involve analyzing system logs and network traffic), assess the impact of the attack (for example, data loss), improve future

response strategies, and identify areas for improvement in the university's security posture.

Question 4: Who or what groups will be involved? Suggest measures to contain and recover from the incident

Employees

All employees play a crucial role. They should be trained to identify suspicious activity like:

- Unexpected emails from unknown senders.
- Phishing attempts that try to trick them into revealing login credentials or clicking malicious links.
- Unusual system behaviour like sluggish performance, pop-up windows, or unexpected error messages.

System Administrator

- Identifying infected machines and the scope of the attack.
- Isolating the infected machines to prevent further spread within the network.
- Analyzing system logs and network traffic to determine the root cause.
- Coordinating with the security team or external experts if necessary.

This leads to eradicating the threat, which might include rebooting infected machines in safe mode and running antivirus scans, reinstalling the operating system if necessary, and applying security updates and patches to all university systems.

Management

- Provides resources and support for the response and recovery efforts, and ensures clear communication with stakeholders throughout the process.
- Makes critical decisions regarding business continuity (maintaining critical university functions during the disruption), recovery prioritization (deciding which systems and data need to be restored first), and external communication (determining the appropriate level of transparency with the university community and potentially the public).

Legal and Public Relations

In severe cases involving data breaches or legal implications, legal counsel and public relations teams may be involved. They can advise on legal obligations for reporting data breaches and on developing a communication strategy to address concerns from students, staff, and the public.

Containment and Recovery Measures

Communication and transparency: establish a clear communication plan to keep stakeholders informed throughout the incident response process; provide regular updates on the situation, the containment efforts, and the estimated timeline for recovery; be transparent about the

impact of the attack, but avoid disclosing sensitive details that could compromise the ongoing investigation.

Data backups and recovery: regularly back up critical university data to a secure offsite location, ensuring faster and more complete recovery in case of a cyberattack; test data backups regularly to ensure they are functional and readily available for recovery.

User education and training: following a cyberattack, provide additional security awareness training to address the specific vulnerabilities exploited in the attack, and reinforce best practices for identifying and reporting suspicious activity.

Question 5: What's the severity level of the above mentioned incident? Suggest actions to improve the detection of similar events

Severity Level

The severity level of the incident can be classified as Medium, based on the following:

- **Impact:** the attack caused a one-day suspension of lab activities, resulting in inconvenience and potentially impacting academic schedules or research. However, there is no mention of data loss or compromise of critical systems.
- **Scope:** the worm appears to have infected multiple computers within the lab network, suggesting a moderate spread.
- **Disruption:** the incident caused significant disruption to lab operations, highlighting the potential consequences of cyberattacks.

Improved Detection Methods

Intrusion Detection/Prevention Systems (IDS/IPS): deploy IDS/IPS to monitor for signs of unauthorized access, malware infection, and other security threats. These systems can provide real-time alerts on suspicious activity.

Endpoint Detection and Response (EDR): utilize an EDR solution to monitor endpoints for malicious activity, detect advanced threats, and facilitate rapid response. EDR can provide deeper visibility into endpoint activity compared to traditional antivirus software.

Security Awareness Training: ongoing training can empower employees to identify phishing attempts, social engineering tactics, and other suspicious behaviour, leading to earlier detection and reporting of potential threats.

Question 6: Information Security Management Effectiveness

Evaluating Effectiveness at XYZ University

Policy and Procedures: assess the comprehensiveness of the university's information security policy. Does it address areas like patch management, access control, data security, and incident response? Are clear procedures documented for employees to report suspicious activity and follow established protocols during a security incident?

Employee Awareness: evaluate the frequency and effectiveness of security awareness training programs. Do training programs address current cyber threats and provide employees with the knowledge and skills to identify suspicious activity? Is there a culture of security awareness where employees feel empowered to report suspicious activity without fear of reprisal?

Technical Safeguards: assess the strength of the technical safeguards in place. Does the university utilize firewalls, intrusion detection/prevention systems, and antivirus software? Are these safeguards properly configured and maintained?

Vulnerability Management: does XYZ University conduct regular vulnerability assessments and penetration testing to identify and address security weaknesses before they can be exploited? Do they have a process for prioritizing and patching vulnerabilities based on severity and exploit potential?

Incident Response: does the university have a documented incident response plan outlining procedures for detection, reporting, containment, eradication, and recovery? Have they conducted regular tabletop exercises to test the plan and identify areas for improvement? Do they have a dedicated incident response team, or does the burden fall on the IT department?

Recommendations for Improvement

- Develop and implement a comprehensive information security policy that addresses all aspects of information security, including acceptable use, password management, data classification, incident response, and access control.
- Implement ongoing security awareness training that addresses current cyberattacks, best practices for secure computing, and the university's information security policy.
- Maintain strong technical safeguards: utilize firewalls, IDS/IPS, and antivirus software to protect the network and systems, and regularly update and patch these safeguards to address newly discovered vulnerabilities.
- Implement a vulnerability management program: conduct regular vulnerability assessments and penetration testing to identify and address security weaknesses, and prioritize patching vulnerabilities based on severity and exploit potential.
- Develop and test an incident response plan: create a documented incident response plan outlining clear roles and responsibilities for stakeholders, conduct regular tabletop exercises to test the plan and refine its effectiveness, and consider establishing a dedicated incident response team if resources allow.

Benefits of an Effective ISM Program

- **Reduced Risk of Cyberattacks:** helps prevent cyberattacks by addressing vulnerabilities and educating employees.
- **Improved Incident Response:** a well-defined incident response plan ensures a structured approach to handling security incidents, minimizing disruption and maximizing recovery and efficiency.
- **Enhanced Data Protection:** strong technical safeguards and data security practices protect sensitive university data from unauthorized access or loss.

- Increased Compliance: a comprehensive ISM program helps XYZ University comply with relevant industry regulations and data privacy laws.